

Data Classification Policy

Nimbus Analytics Inc. -- Security Department

Effective Date: November 1, 2025

1. Purpose

This policy defines the classification tiers used to label company and customer data, and the minimum handling requirements for each tier, in support of our SOC 2 and GDPR compliance obligations.

2. Classification Tiers

Tier 1 (Restricted): customer personal data, payment information, authentication credentials, and employee SSNs. Tier 2 (Confidential): internal financial reports, unreleased product plans, and vendor contracts. Tier 3 (Internal): internal documentation, meeting notes, and non-sensitive operational data. Tier 4 (Public): marketing materials and published documentation.

3. Handling Requirements by Tier

Tier 1 data must be encrypted at rest (AES-256) and in transit (TLS 1.2+), access-logged, and restricted to named individuals with a documented business need, reviewed quarterly per the Access Control Policy. Tier 2 data requires encryption in transit and role-based access control. Tier 3 data is accessible to all employees by default. Tier 4 data has no handling restrictions.

4. Labeling

All documents and data stores must be labeled with their classification tier in the filename, metadata, or document header. Systems storing Tier 1 data must be registered in the Data Inventory maintained by the Security team.

5. Data Sharing

Sharing Tier 1 or Tier 2 data outside the company requires a signed Data Processing Agreement (DPA) or NDA, consistent with the Vendor Contract Summary process. Sharing Tier 1 data via unencrypted email or personal cloud storage is strictly prohibited.

6. Retention and Deletion

Data classification tier determines the applicable retention schedule; see the Data Retention Policy for tier-specific retention periods and deletion procedures.

7. Breach Handling

Any suspected exposure of Tier 1 data must be reported immediately to security-incidents@nimbusanalytics.example and triggers the Incident Response Policy, including potential regulatory notification obligations under GDPR.

8. Annual Review

This policy and its tier assignments are reviewed annually by the Security and Legal teams, or upon introduction of a new data type.